

Analysis of the App

Privacy Analysis of Augmented Reality Glasses

1 Introduction

This report focuses on a static analysis of the Meta View app, the companion application for the Meta Ray-Ban glasses. The analysis aims to see the potential vulnerabilities, excessive permissions, and insecure coding practices within the app, which may compromise user privacy or security. The app serves as the primary interface between the glasses and Meta's backend services, making it a critical component in understanding the privacy implications of the device.

To perform this analysis, the Mobile Security Framework (MobSF) was used to inspect the app's APK. The process of the set-up can be found in the file 'SetUp MobSF'. MobSF provides a comprehensive analysis, revealing details about permissions, activities, API usage, hardcoded secrets, etc. This creates a foundation for understanding the network behavior and privacy risks associated with the Meta Ray Ban glasses.

2 Static Analysis

2.1 Permissions

Permissions in Android apps determine the scope of access an application has to a device's data and system functionalities. The Meta View app requests several permissions that are considered as dangerous by the Android operating system. Although they appear necessary for the app's intended functionality, such as managing connectivity with the Meta Ray Ban glasses, several permissions raise potential risks as improper use of these permissions could lead to either unauthorized access to sensitive user data or potential data leakage and privacy violations as these permissions provide access to sensitive user data and device functionality. The analysis of these permissions and their potential implications are categorized based on the type of permission:

2.1.1 Location Permissions

- Access Location in Background:
Allows the app to access location data even when it is not actively in use by the user.
This allows continuous tracking of the user's movements without their knowledge, leading to privacy violations.
- Coarse (Network-Based) Location:
Determines an approximate location using network data, such as cell towers.
This allows malicious apps to get an idea of the user's general location, potentially compromising user privacy.
- Fine (GPS) Location:
Provides precise location data using GPS.
This allows malicious apps to pinpoint the user's exact location, increasing the risk of targeted surveillance or physical tracking.

2.1.2 Bluetooth Permissions

- Bluetooth Connect:
Required for the app to connect to paired Bluetooth devices.
This could result in unauthorized access to connected devices.

- **Bluetooth Scan:**
Required for the app to discover and pair with nearby Bluetooth devices.
This could result in potential attacks to the user from malicious devices in proximity.

2.1.3 Account and Device Connectivity Permissions

- **Get Accounts:**
Allows access to the list of accounts registered on the device in the Accounts Service.
This allows malicious apps to identify and potentially misuse sensitive account details.
- **Nearby Wi-Fi Devices:**
Required for the app to advertise and connect to nearby devices via Wi-Fi.
This allows malicious apps to make unauthorized connections and possible data interception.

2.1.4 Notifications

- **Post Notifications:**
Allows the app to post notifications.
This could be exploited for phishing attempts via fake notifications.

2.1.5 Phone and Call Permissions

- **Read Call Log:**
Allows the app read access to the user's call history.
This could result in unauthorized access to call details.
- **Read Contact Data:**
Allows the app read access to all contact address data on the phone.
This allows malicious apps to access and distribute the user's data.
- **Read Phone State:**
Allows the app read access to SMS messages stored on the device or SIM card.
This allows malicious apps to read confidential messages, potentially fingerprinting or tracking the user.

2.1.6 Storage and Media Permissions

- **Read External Storage Contents:**
Allows the app to read data from external storage, such as documents and media files.
This could result in access to sensitive files without user consent.
- **Read Media Images/Videos/Visual Content:**
Allows read access to the user's image, video, and visual media files from external storage.
This allows unauthorized access or distribution of personal media.
- **Write External Storage:**
Allows the app to read/modify/delete data in external storage.
This could result in malicious data or files being written, potentially corrupting storage or allowing further attacks.

2.1.7 Communication and Messaging Permissions

- **Read SMS Messages:**
Allows the app read access the user's SMS or MMS messages stored on the user's phone or SIM card.
This allows malicious apps to read confidential or sensitive messages.
- **Send SMS Messages:**
Allows the app to send SMS messages.
This allows malicious apps to send messages without the user's knowledge, resulting in financial costs or phishing attacks.

- **Receive SMS or MMS:**
Allows the app to access and process incoming SMS and MMS messages.
This allows malicious apps to monitor the user's messages or delete them without the user's knowledge, messages such as verification codes or private conversations.

2.2 Abused Permissions

The following lists the permissions considered 'dangerous' that are in the top malware permissions, which are permissions that are widely abused by known malware. 16 out of 24 permissions commonly associated with malware are present in the Meta View app. These permissions allow access to highly sensitive data or critical system features such as storage, location, SMS, and phone state and if abused, can expose users to threats such as unauthorized data collection, or surveillance.

- **Read or Write external storage**
Could allow unauthorized access to or manipulation of sensitive user files, including personal documents, images, or videos.
- **Access coarse or fine location**
Could lead to continuous tracking of the user's physical location.
- **Access network state or wifi state**
Could be used to track the user's connectivity behavior.
- **Internet**
Allows communication with remote servers.
Could allow for unauthorized data transmission.
- **Wake lock**
Prevents the device from entering sleep mode. Drains battery life unnecessarily and could keep the app running in the background without the user's explicit awareness.
- **Receive boot completed**
Allows the app to start automatically after the device boots.
Could result in app performing unauthorized background activities without user consent.
- **Send or Read or Receive SMS**
Could allow unauthorized access to user communications.
- **Read call log or contacts**
Could lead to the unauthorized use or sharing of contact numbers or durations or contact data.
- **Read phone state**
Could allow device tracking or identification.
- **Get accounts**
Could allow access to sensitive account details, which could be used for impersonation.

The following lists the 8 out of 45 other common permissions that are in the Meta View app which are commonly abused by known malware in Android applications. While they are not classified as malware permissions, some of these common permissions also have privacy or security risks.

- **Foreground service**
Allows the app to track location even when it is not actively in use.
Could allow for continuous background activity, which drains battery life unnecessarily or continuous data collection without the user's explicit awareness.
- **Change network state or wifi state**
Could lead to potential unauthorized network activity.
- **Bluetooth or Bluetooth Admin**
Could allow unauthorized device to connect if Bluetooth communication is not secured.
- **Access background location**
Allows for tracking of the user's location.

- **Modify audio settings**
Allows for a better audio experience
Could allow for modifications of audio settings without user consent.
- **Receive**
This is different from the other permissions where it is `com.google.android.c2dm.permission.RECEIVE`, which means it allows Google Cloud Messaging (GCM) push notifications.
Could be used to send spam or lightweight data packets to and from the app which goes unnoticed by the user.

2.3 API Usage

ANDROID API

2.4 Network Security

The network configuration of the Meta View app shows several vulnerabilities that is considered as high risks to users. These findings are categorized based on their severity and scope. The following looks into those that were categorized as high risk issues:

2.4.1 Permitting Clear Text Traffic

- **Scope:**
, meaning it applies to all domains
- **Severity:**
High
- **Description:**
The app is configured to allow clear text traffic (unencrypted HTTP connections) to all domains. This practice is inherently insecure as it does not encrypt data in transit. This makes it so that any data sent over HTTP like login credentials is visible to anyone who can monitor the network. Meaning that it is easier for attackers to intercept sensitive data like user credentials or API requests by using tools like packet sniffers during transit.
- **Implications:**
Unencrypted traffic increases the risk attacks such as man-in-the-middle (MITM) attacks which results in user data being exposed to eavesdroppers on insecure networks.

2.4.2 Trusting System Certificates

- **Scope:**
, meaning it applies to all domains
- **Severity:**
Warning
- **Description:**
The app trusts certificates installed in the system store. While this is considered to be standard behavior, it introduces risks if the system store contains compromised or malicious certificates.
- **Implications:**
A compromised system certificate could allow an attacker to impersonate a legitimate trusted server which results in user data being exposed to malicious parties.

2.4.3 Trusting User-Installed Certificates

- **Scope:**
, meaning it applies to all domains
- **Severity:**
High

- **Description:**
The app is configured to trust user-installed certificates. Some examples could be for debugging or testing, however, they are inherently insecure in production environments as a malicious party with physical access to the device can install a compromised certificate.
- **Implications:**
A compromised certificate installed by a malicious party with physical or administrative access to the device intercept encrypted communications and sensitive data such as authentication tokens or personal information.

2.4.4 ByPassing Certificate Pinning

- **Scope:**
, meaning it applies to all domains
- **Severity:**
High
- **Description:**
The app bypasses certificate pinning, which is a security measure that ensures communications are only established with trusted servers by validating their public keys. Without certificate pinning, attackers could present fake certificates to the app, and the app would not be able to distinguish between legitimate and malicious servers.
- **Implications:**
This bypass undermines the ability of the app to ensure secure server communication and could result in sensitive data such as tokens or passwords to be exposed to malicious parties.

2.4.5 Permitting Clear Text Traffic for Specific Domains

- **Scope:**
Specific Facebook and Instagram domains, such as:
 - h.facebook.com
 - l.facebook.com
 - l.alpha.facebook.com
 - lm.facebook.com
 - l.instagram.com
- **Severity:**
High
- **Description:**
The app specifically permits clear text traffic to these domains, which increases the risk of data interception during communication with these endpoints. This is similar to the first point but with specific domains, which means that even if other parts of the app enforce HTTPS, data sent to these domains are still at risk.
- **Implications:**
Sensitive data such as user interactions or session tokens may be transmitted unencrypted. This vulnerability could be exploited by a malicious party by intercepting or manipulating communications.

2.5 Server Locations

The following shows the geolocation of relevant domains for my analysis as well as their corresponding IP addresses.

2.5.1 Meta / Facebook related domains

The following domains are all in Switzerland, Zurich.

- about.facebook.com - 157.240.17.35
- accountscenter.meta.com - 157.240.17.17
- ar.graph.meta.com - 157.240.17.17
- auth.meta.com - 157.240.17.17
- facebook.com - 157.240.17.35
- graph.facebook.com - 157.240.17.17
- lookaside.facebook.com - 157.240.17.15
- m.facebook.com - 157.240.17.35
- meta.com - 157.240.17.17
- shortwave.facebook.com - 157.240.17.13
- prod.facebookvirtualassistant.com - 157.240.17.13
- store.facebook.com - 157.240.17.17
- www.facebook.com - 157.240.17.35

2.5.2 Google related domains

The following domains are all in USA, California, Mountain View.

- accounts.google.com - 74.125.143.84
- developers.google.com - 172.217.168.46
- fb-messaging-b8df1.firebaseio.com - 35.190.39.113
- issuetracker.google.com - 172.217.168.78
- play.google.com - 172.217.168.78

2.5.3 Other related domains

The following domains are all in USA, California, Mountain View.

- www.youtube.com - 172.217.168.46
USA, California, Mountain View.
- www.instagram.com - 157.240.17.174
Switzerland, Zurich, Zurich
- www.ray-ban.com - 193.247.43.225
Switzerland, Bern

2.6 Trackers

The Meta View app includes the Facebook Flipper tracker, which categorized under analytics. Analytics trackers monitor how users interact with the app, such as which features are most used, how long users stay engaged, or where they encounter issues. Flipper tracker allows inspecting and controlling apps through debugging and analyzation. Although the purpose is to help in identifying bugs or improving user experience, it also raises potential privacy concerns as analytics trackers collect data which could include potentially sensitive information especially since some analytics platforms share the collected data with third parties, such as advertising networks or parent companies.

When setting up the app, it is asked if I'd like to store or share additional data. I have opt out on both, however, Facebook Flipper is still integrated into the app even if opt out meaning that the data collected is not considered to be additional data.